



**UNIVERSIDAD TECNOLÓGICA
DE QUERÉTARO**

Alumna:

Vasquez Noyola Andrea

Grupo:

IDGS17

Matrícula:

2023148002

Materia:

Seguridad en el Desarrollo de Aplicaciones

Práctica 2 - Parte 2

En este reporte, se describen las pruebas realizadas, en este caso, en el módulo de comentarios, donde se logró inyectar y ejecutar exitosamente el script `<script>alert('XSS')</script>` para demostrar la vulnerabilidad de la seguridad en el código.

El navegador ejecuta el script malicioso porque la aplicación web recibe el texto desde la base de datos (o memoria) y lo inserta directamente en el documento HTML utilizando la instrucción `@Html.Raw()`. Esta instrucción le indica al motor de renderizado que confíe ciegamente en el contenido y no escape las etiquetas HTML, provocando que el navegador lo lea como código ejecutable en lugar de texto plano.

Un ataque exitoso pone en riesgo crítico a los usuarios de la aplicación. Un atacante podría inyectar código para robar cookies de sesión, capturar pulsaciones de teclado, redirigir al usuario a sitios fraudulentos (phishing) o realizar acciones no autorizadas en nombre del usuario legítimo.

Relación con validación y codificación Este hallazgo evidencia una doble falla de seguridad:

1. Falta de validación de entrada: El servidor (CommentController) acepta cualquier cadena de texto sin verificar si contiene caracteres peligrosos como `<` o `>`.
2. Falta de codificación de salida: Al renderizar la vista, no se transforman los caracteres especiales en sus entidades HTML correspondientes (ej. `<` a `<`). Si se aplicara codificación de salida, el navegador interpretaría el script como simple texto visual.